Anlage 3 – Vereinbarung zur Auftragsverarbeitung nach Art. 28 DSGVO

Entwurf – unverbindlich, Stand 11/2026. Maßgeblich ist der im Einzelfall unterzeichnete Vertrag.

Zwischen dem **Kunden** als Verantwortlichem ([Firma / Name], [Anschrift]) und **torecon** als Auftragsverarbeiter (Thomas Reinke, Roesgenstr. 22, 53474 Ahrweiler, info@torecon.de). Angebote von torecon richten sich ausschließlich an Unternehmer und Selbständige im Sinne von § 14 BGB.

1. Gegenstand und Dauer

1. Diese Vereinbarung regelt die Verarbeitung personenbezogener Daten durch torecon im Auftrag des Kunden im Rahmen des Entwicklungsvertrags App vom [Datum] sowie einer etwaigen Wartungsvereinbarung (im Folgenden „Hauptvertrag“).
2. Sie gilt, solange torecon Zugriff auf personenbezogene Daten des Kunden hat, längstens bis zum Ende des Hauptvertrags und der Löschung bzw. Rückgabe nach Ziffer 9.

2. Art und Zweck der Verarbeitung

torecon verarbeitet personenbezogene Daten nur, soweit dies für die Leistungen des Hauptvertrags nötig ist, insbesondere:

- Einrichtung, Test und Fehleranalyse von Backend, Datenbank und Speicher,
- Einsicht in Protokolle (Logs) zur Fehlersuche,
- Bearbeitung von Support-Anfragen, die der Kunde an torecon weiterleitet,
- Migration oder Wiederherstellung von Daten auf Weisung des Kunden.

Eine Verarbeitung zu eigenen Zwecken von torecon findet nicht statt.

3. Art der Daten und Kategorien betroffener Personen

Angabe	Inhalt
Datenarten	[z. B. Kontaktdaten (Name, E-Mail), Nutzungs- und Gerätedaten, Inhalte der Nutzer, Abo-Status, Protokolldaten (IP-Adresse, Zeitstempel)]

Angabe	Inhalt
Besondere Kategorien (Art. 9 DSGVO)	[keine / Angabe, z. B. Gesundheitsdaten]
Betroffene Personen	[z. B. Nutzer der App, Interessenten, Beschäftigte des Kunden]

4. Weisungen

1. torecon verarbeitet die Daten nur auf dokumentierte Weisung des Kunden. Der Hauptvertrag und diese Vereinbarung gelten als Weisung. Einzelweisungen erteilt der Kunde in Textform (E-Mail genügt).
2. Weisungsberechtigt beim Kunden: [Name, E-Mail]. Weisungsempfänger bei torecon: Thomas Reinke, info@torecon.de.
3. Hält torecon eine Weisung für rechtswidrig, weist torecon den Kunden unverzüglich darauf hin und darf die Ausführung bis zur Bestätigung oder Änderung aussetzen.
4. Ist torecon gesetzlich zu einer anderen Verarbeitung verpflichtet, teilt torecon dies dem Kunden vorher mit, soweit das Gesetz dies nicht verbietet.

5. Vertraulichkeit

torecon wahrt die Vertraulichkeit der Daten. Setzt torecon mit Zustimmung des Kunden weitere Personen ein, werden diese vorher zur Vertraulichkeit verpflichtet. Die Pflicht besteht über das Ende dieser Vereinbarung hinaus.

6. Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

torecon trifft insbesondere folgende Maßnahmen:

1. **Zugriff nur über Konten des Kunden:** torecon greift ausschließlich über Zugänge zu, die der Kunde einräumt (Teammitglied mit minimal nötiger Rolle). Für alle Konten ist Zwei-Faktor-Authentisierung aktiv. Es werden keine Passwörter geteilt.
2. **Verschlüsselte Geräte:** Alle Arbeitsgeräte von torecon sind vollständig verschlüsselt, mit Passwort bzw. biometrisch gesperrt und erhalten zeitnah Sicherheitsupdates.
3. **Passwortmanager:** Eigene Zugangsdaten verwaltet torecon in einem verschlüsselten Passwortmanager; Schlüssel und Tokens werden nicht im Quellcode gespeichert.
4. **Keine lokalen Kopien:** Produktionsdaten werden ohne Weisung des Kunden nicht lokal gespeichert, exportiert oder in Testumgebungen kopiert. Für Tests verwendet torecon erfundene Testdaten.

5. **Keine Eingabe in externe Werkzeuge:** Personenbezogene Produktionsdaten werden nicht in KI-Assistenten oder andere externe Dienste eingegeben, sofern der Kunde das nicht ausdrücklich anweist.
6. **Verschlüsselte Übertragung:** Datenübertragungen erfolgen ausschließlich verschlüsselt (TLS).
7. **Datensparsamkeit:** torecon sieht Daten nur ein, soweit dies für die konkrete Aufgabe nötig ist, und gestaltet Protokolle so, dass sie möglichst keine personenbezogenen Daten enthalten.

torecon darf die Maßnahmen weiterentwickeln, sofern das Schutzniveau nicht sinkt.

7. Unterauftragsverarbeiter

1. Die Anbieter des Technik-Stacks (z. B. Apple, Google, GitHub, Railway, Anthropic, Hetzner) sind **direkte Vertragspartner des Kunden** und keine Unterauftragsverarbeiter von torecon. Den Abschluss der erforderlichen Datenschutzvereinbarungen mit diesen Anbietern übernimmt der Kunde.
2. torecon setzt in der Regel **keine Unterauftragsverarbeiter** ein. Ein Einsatz erfolgt nur nach vorheriger Zustimmung des Kunden in Textform und mit einer Vereinbarung, die den Anforderungen von Art. 28 DSGVO entspricht.
3. torecon verarbeitet die Daten nicht außerhalb der EU bzw. des EWR, soweit der Kunde nichts anderes anweist.

8. Unterstützungspflichten

torecon unterstützt den Kunden im Rahmen des Zumutbaren und mit den verfügbaren Informationen

- bei der Beantwortung von Anfragen betroffener Personen (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch); Anfragen, die bei torecon eingehen, leitet torecon unverzüglich an den Kunden weiter,
- bei der Sicherheit der Verarbeitung, bei Datenschutz-Folgenabschätzungen und bei Konsultationen der Aufsichtsbehörde (Art. 32 bis 36 DSGVO),
- bei Datenschutzverletzungen: torecon meldet dem Kunden eine bekannt gewordene Verletzung des Schutzes personenbezogener Daten **unverzüglich**, möglichst innerhalb von 24 Stunden, mit den bis dahin vorliegenden Informationen.

Unterstützung, die über die vereinbarten Leistungen hinausgeht und nicht auf einem Verstoß von torecon beruht, kann torecon nach Aufwand abrechnen, sofern dies vorher vereinbart wurde.

9. Löschung und Rückgabe

Nach Ende der Leistungen oder auf Weisung des Kunden löscht torecon alle personenbezogenen Daten, die ausnahmsweise bei torecon vorliegen, oder gibt sie nach Wahl des Kunden zurück, soweit keine gesetzliche Aufbewahrungspflicht besteht. Der Kunde entfernt die Zugriffsrechte von torecon in seinen Konten. torecon bestätigt die Löschung auf Wunsch in Textform.

10. Nachweise und Kontrollen

1. torecon stellt dem Kunden auf Anfrage die Informationen zur Verfügung, die zum Nachweis der Pflichten aus Art. 28 DSGVO nötig sind.
2. Der Kunde oder ein von ihm beauftragter, zur Verschwiegenheit verpflichteter Prüfer kann die Einhaltung nach rechtzeitiger Ankündigung (in der Regel zwei Wochen) während der üblichen Geschäftszeiten überprüfen, ohne den Betriebsablauf unverhältnismäßig zu stören. Vorrangig erfolgt die Prüfung durch Auskunft und Vorlage von Unterlagen.

11. Schlussbestimmungen

Für die Haftung gilt Art. 82 DSGVO; im Übrigen gelten die Regelungen des Hauptvertrags. Bei Widersprüchen zwischen dieser Vereinbarung und dem Hauptvertrag geht diese Vereinbarung in Fragen des Datenschutzes vor. Änderungen bedürfen der Textform.

Ort, Datum	**Ort, Datum**
Kunde (Verantwortlicher) – [Name, Funktion]	**torecon** (Auftragsverarbeiter) – Thomas Reinke